

Data leak worksheet

Data leak worksheet

Incident summary: A sales manager shared access to a folder of internal-only documents with their team during a meeting. The folder contained files associated with a new product that has not been publicly announced. It also included customer analytics and promotional materials. After the meeting, the manager did not revoke access to the internal folder, but warned the team to wait for approval before sharing the promotional materials with others.

During a video call with a business partner, a member of the sales team forgot the warning from their manager. The sales representative intended to share a link to the promotional materials so that the business partner could circulate the materials to their customers. However, the sales representative accidentally shared a link to the internal folder instead. Later, the business partner posted the link on their company's social media page assuming that it was the promotional materials.

Control	Least privilege
Issue(s)	<i>The primary factor contributing to the leak was the lack of access management for the folder and the creation of unrestricted links. Access to the internal folder was not restricted solely to the sales team and the manager. Additionally, the sales representative failed to verify the link's content before sharing it. Finally, the business partner should not have had the permissions or the ability to share the promotional information on social media.</i>
Review	<i>NIST SP 800-53: AC-6 addresses how an organization can protect data privacy through the concept of least privilege. This means that every user must have access to—and be authorized to use—only those resources strictly necessary to perform their job. Furthermore, the document suggests implementing control enhancements to increase the effectiveness</i>

	<i>of this principle.</i>
Recommendation(s)	<i>Restrict access to sensitive resources based on each user's role by implementing appropriate authorization and authentication systems. Additionally, it is essential to periodically audit user privileges to maintain control over access over time.</i>
Justification	<i>Data leaks can be prevented by restricting shared links to internal files so that no one without a user account or role within the organization can access them. For example, a manager could grant temporary access solely for the duration of a meeting and then ensure it is revoked. Furthermore, requiring managers and security teams to regularly audit access to team files would help significantly limit the exposure of sensitive information.</i>

Security plan snapshot

The NIST Cybersecurity Framework (CSF) uses a hierarchical, tree-like structure to organize information. From left to right, it describes a broad security function, then becomes more specific as it branches out to a category, subcategory, and individual security controls.

Function	Category	Subcategory	Reference(s)
Protect	PR.DS: <i>Data security</i>	PR.DS-5: <i>Protections against data leaks.</i>	NIST SP 800-53: AC-6

In this example, the implemented controls that are used by the manufacturer to protect against data leaks are defined in NIST SP 800-53—a set of guidelines for securing the privacy of information systems.

Note: References are commonly hyperlinked to the guidelines or regulations they relate to. This makes it easy to learn more about how a particular control should be implemented. It's common to find multiple links to different sources in the references columns.

NIST SP 800-53: AC-6

NIST developed SP 800-53 to provide businesses with a customizable information privacy plan. It's a comprehensive resource that describes a wide range of control categories. Each control provides a few key pieces of information:

- **Control:** A definition of the security control.
- **Discussion:** A description of how the control should be implemented.
- **Control enhancements:** A list of suggestions to improve the effectiveness of the control.

AC-6	Least Privilege
	Control: Only the minimal access and authorization required to complete a task or function should be provided to users.
	Discussion: Processes, user accounts, and roles should be enforced as necessary to achieve least privilege. The intention is to prevent a user from operating at privilege levels higher than what is necessary to accomplish business objectives.
	Control enhancements: ● Restrict access to sensitive resources based on user role. ● Automatically revoke access to information after a period of time. ● Keep activity logs of provisioned user accounts. ● Regularly audit user privileges.

Note: In the category of access controls, SP 800-53 lists least privilege sixth, i.e. AC-6.

Hoja de trabajo de filtración de datos

Hoja de trabajo de filtración de datos

Resumen del incidente: Un gerente de ventas compartió el acceso a una carpeta de documentos exclusivamente internos con su equipo durante una reunión. La carpeta contenía archivos asociados con un nuevo producto que no se ha anunciado públicamente. También incluía analíticas de clientes y materiales promocionales. Después de la reunión, el gerente no revocó el acceso a la carpeta interna, pero advirtió al equipo que esperará la aprobación antes de compartir los materiales promocionales con otras personas.

Durante una videollamada con un socio comercial, un miembro del equipo de ventas olvidó la advertencia de su gerente. El representante de ventas tenía la intención de compartir un enlace a los materiales promocionales para que el socio comercial pudiera distribuirlos a sus clientes. Sin embargo, el representante de ventas compartió accidentalmente un enlace a la carpeta interna. Más tarde, el socio comercial publicó el enlace en la página de redes sociales de su empresa asumiendo que se trataba de los materiales promocionales.

Control	Mínimo privilegio
Problema(s)	<i>El principal factor que contribuyó a la filtración fue la falta de gestión de acceso a la carpeta y la creación de enlaces sin restricciones. El acceso a la carpeta interna no se limitó exclusivamente al equipo de ventas y al gerente. Además, se suma el desconocimiento del representante de ventas al compartir un enlace sin verificar su contenido. Finalmente, el socio comercial no debió contar con los permisos ni la posibilidad de compartir la información promocional en redes sociales.</i>
Revisión	<i>El NIST SP 800-53: AC-6 aborda cómo una organización puede proteger la privacidad de sus datos mediante el concepto de mínimo privilegio. Esto significa que todo usuario debe tener acceso y estar autorizado a usar solo</i>

	<i>los recursos estrictamente necesarios para cumplir con su trabajo. Además, este documento sugiere la aplicación de mejoras de control para aumentar la efectividad de este principio.</i>
Recomendación(es)	<i>Restringir el acceso a los recursos confidenciales en función del rol de cada usuario, implementando sistemas de autorización y autenticación adecuados. Adicionalmente, es fundamental auditar periódicamente los privilegios de los usuarios para mantener el control de los accesos a lo largo del tiempo.</i>
Justificación	<i>Las filtraciones de datos pueden prevenirse si los enlaces compartidos a archivos internos están restringidos de forma que ninguna persona sin usuario o rol en la organización pueda acceder. Por ejemplo, el gerente podría otorgar un acceso temporal exclusivamente durante la reunión y luego asegurarse de revocarlo. Además, requerir que los gerentes y los equipos de seguridad auditen regularmente el acceso a los archivos del equipo ayudaría a limitar en gran medida la exposición de información confidencial.</i>

Instantánea del plan de seguridad

El Marco de Ciberseguridad de NIST (CSF) utiliza una estructura jerárquica en forma de árbol para organizar la información. De izquierda a derecha, describe una función general de seguridad y luego se vuelve más específico a medida que se ramifica en una categoría, subcategoría y controles de seguridad individuales.

Función	Categoría	Subcategoría	Referencia(s)
Proteger	PR.DS: <i>Seguridad de datos</i>	PR.DS-5: <i>Protecciones contra fugas de datos.</i>	NIST SP 800-53: AC-6

En este ejemplo, los controles implementados que utiliza el fabricante para proteger contra fugas de datos se definen en NIST SP 800-53, un conjunto de pautas para garantizar la privacidad de los sistemas de información.

Nota: Las referencias suelen estar hipervinculadas a las pautas o regulaciones con las que se relacionan. Esto facilita obtener más información sobre cómo se debe implementar un control determinado. Es común encontrar múltiples enlaces a diferentes fuentes en las columnas de referencias.

NIST SP 800-53: AC-6

NIST desarrolló SP 800-53 para proporcionar a las empresas un plan de privacidad de la información personalizable. Es un recurso integral que describe una amplia gama de categorías de control. Cada control proporciona algunas piezas clave de información:

- **Control:** Una definición del control de seguridad.
- **Discusión:** Una descripción de cómo debe implementarse el control.
- **Mejoras de control:** Una lista de sugerencias para mejorar la efectividad del control.

AC-6	Mínimo privilegio
	Control: Solo se debe proporcionar a los usuarios el acceso y la autorización mínimos necesarios para completar una tarea o función.
	Discusión: Los procesos, las cuentas de usuario y los roles deben aplicarse según sea necesario para lograr el mínimo privilegio. La intención es evitar que un usuario opere en niveles de privilegio superiores a los necesarios para lograr los objetivos comerciales.
	Mejoras de control: ● Restringir el acceso a recursos confidenciales en función del rol del usuario. ● Revocar automáticamente el acceso a la información después de un período de tiempo. ● Mantener registros de actividad de las cuentas de usuario aprovisionadas. ● Auditar periódicamente los privilegios de los usuarios.

Nota: En la categoría de controles de acceso, SP 800-53 enumera el mínimo privilegio en sexto lugar, es decir, AC-6.